

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



Práctica: Nessus Scanner

Informe de práctica

Víctor José Santos Guzmán

Information Security

Cybersecurity / Cloud / Networks / GRC

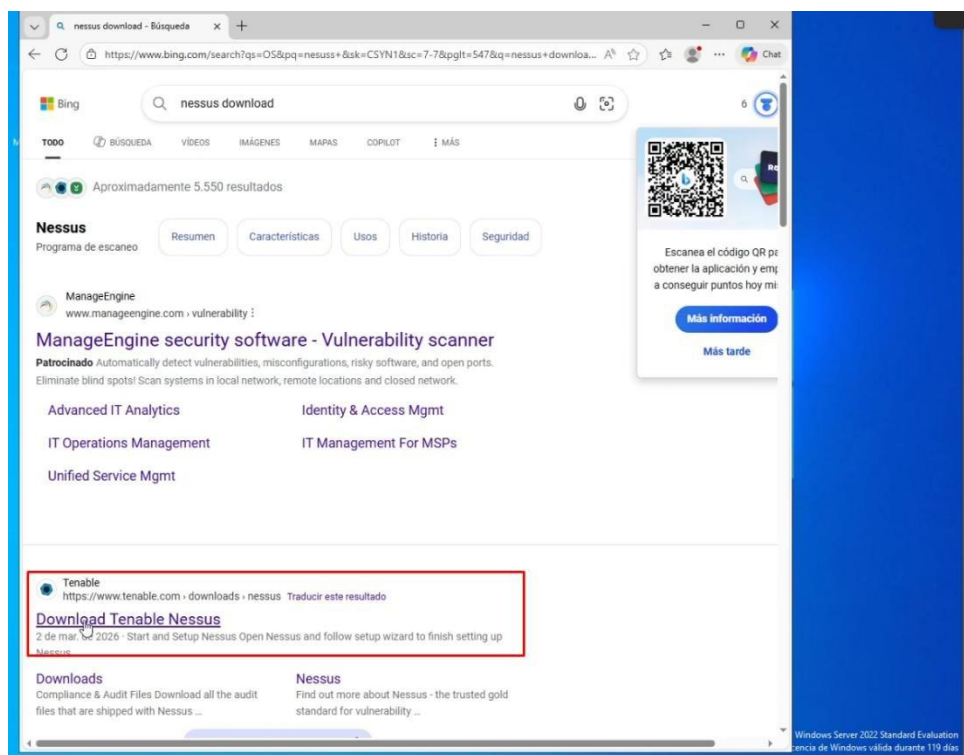


Paso 0: Comienzo la práctica implementando Nessus Essentials, una herramienta líder que aporta visibilidad crítica a la empresa mediante el escaneo automatizado de activos y la detección proactiva de brechas. Su capacidad para programar auditorías recurrentes y su integración con bases de datos globales de amenazas permiten optimizar los tiempos de respuesta, garantizando un cumplimiento normativo riguroso y una reducción drástica de la superficie de ataque en nuestra infraestructura de red.

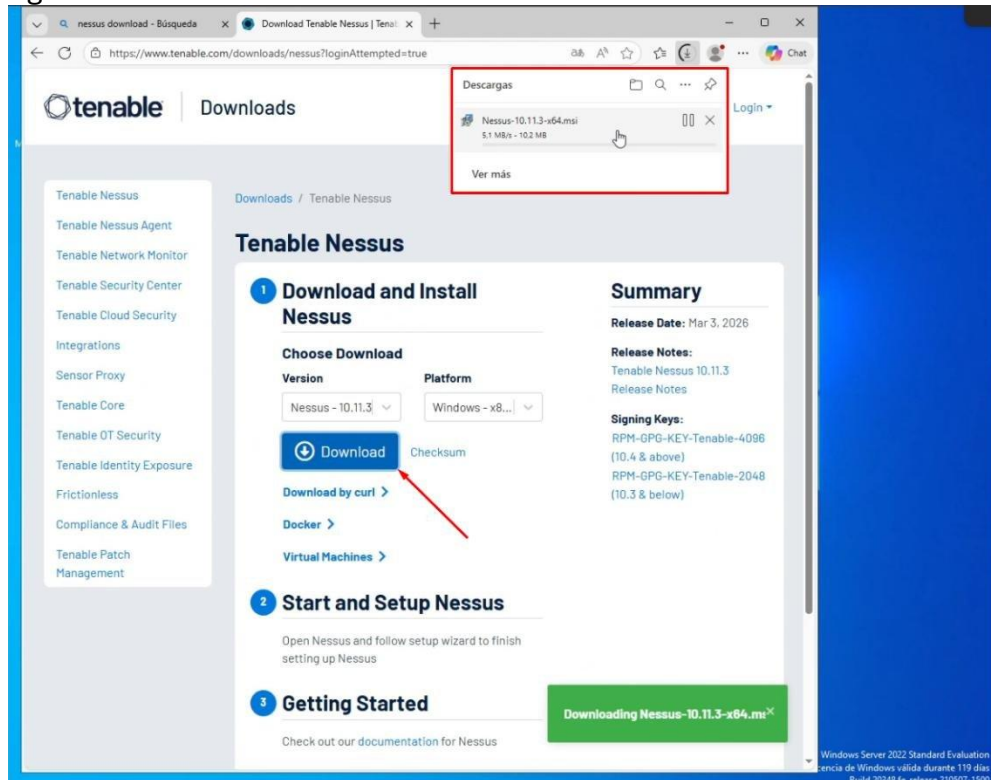


Nessus[®]
vulnerability scanner

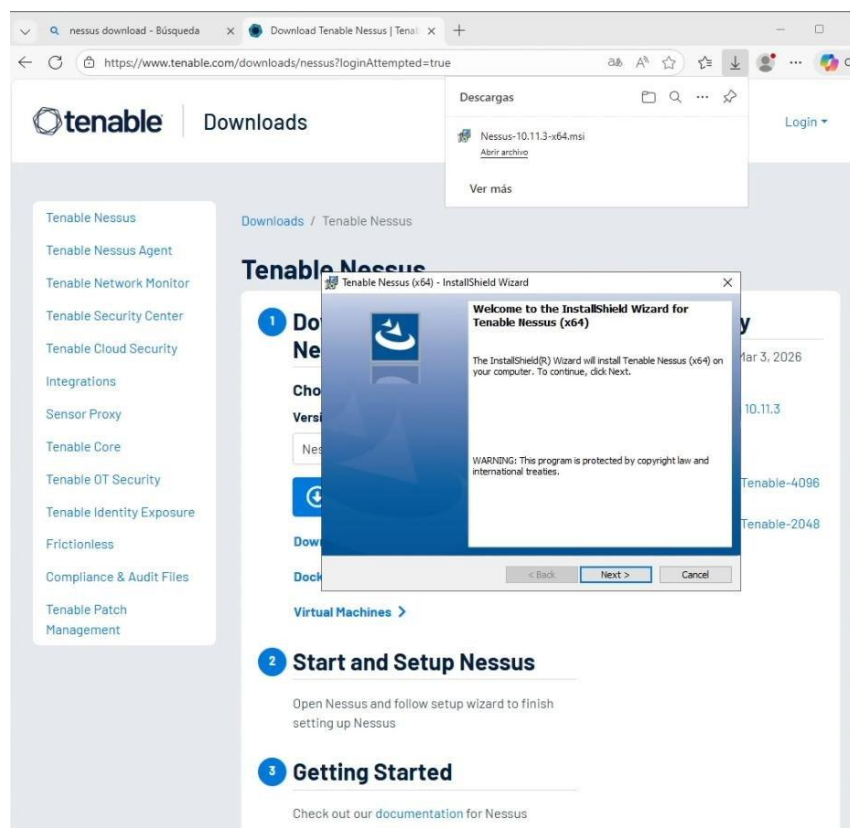
Paso 1: Inicio la búsqueda del software en el navegador utilizando Bing para localizar el sitio oficial de Tenable, donde selecciono el enlace "Download Tenable Nessus" para acceder a la sección de descargas del producto.



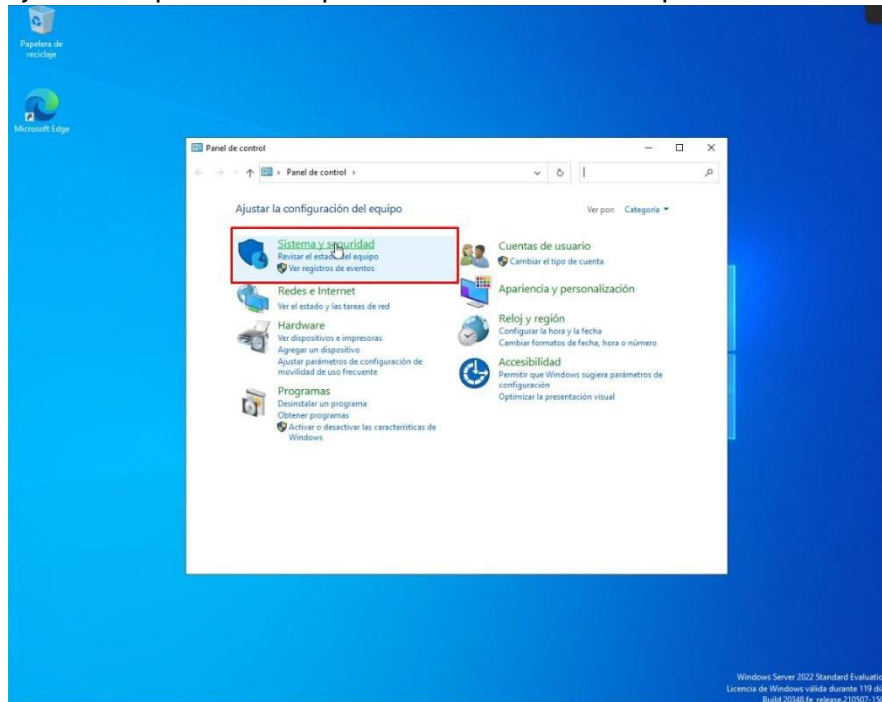
Paso 2: En la página de Tenable, selecciono la versión Nessus-10.11.3 para la plataforma Windows de 64 bits y hago clic en el botón "Download" para iniciar la descarga del instalador MSI en mi servidor local.



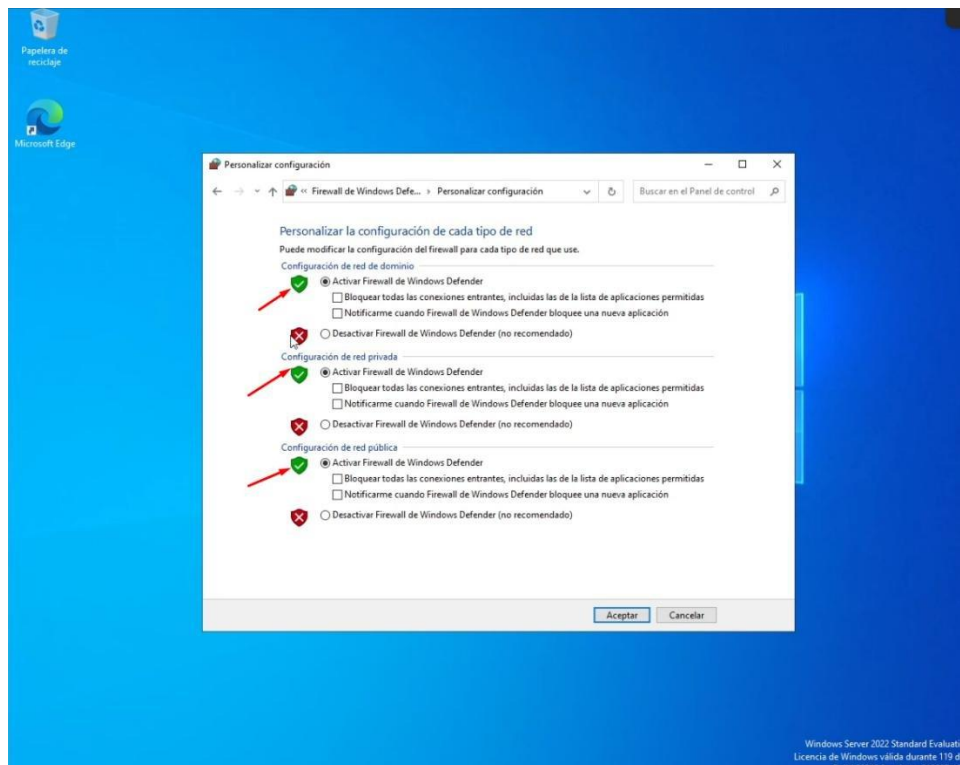
Paso 3: Una vez descargado el archivo Nessus-10.11.3-x64.msi, ejecuto el asistente de instalación **InstallShield Wizard** y presiono "Next" para comenzar el despliegue del escáner de vulnerabilidades en el sistema.



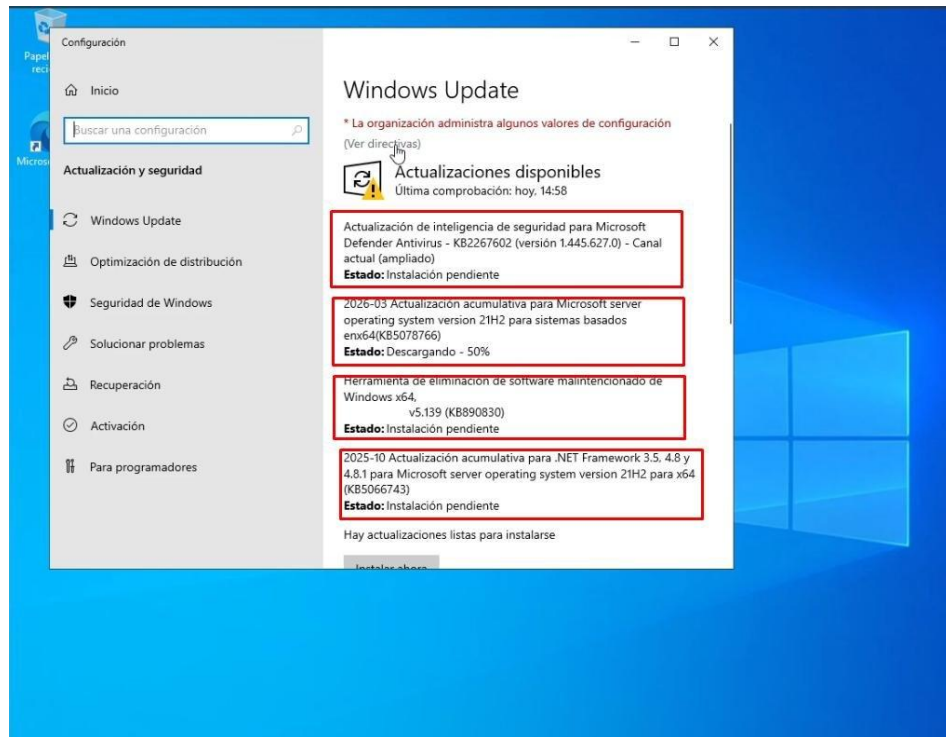
Paso 4: Entro al Panel de Control del servidor y selecciono la categoría de "Sistema y seguridad" para comenzar con la configuración de las vulnerabilidades intencionales, relajando las políticas de protección del sistema operativo.



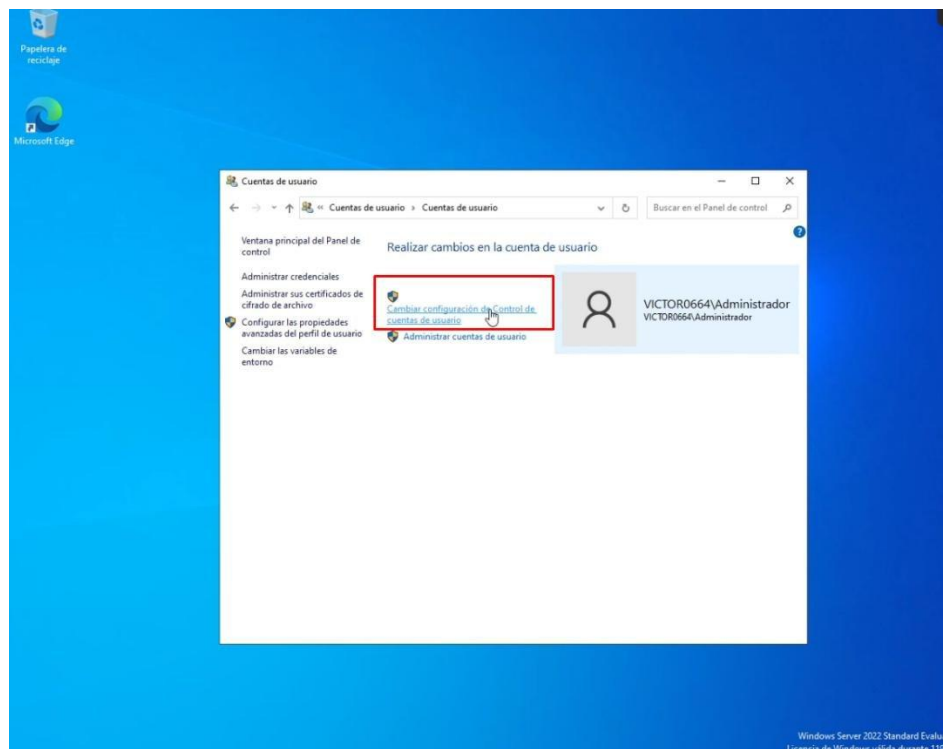
Paso 5: Accedo a la configuración del Firewall de Windows Defender y marco las opciones de "Desactivar Firewall de Windows Defender" en las redes de dominio, privada y pública para permitir el libre flujo de tráfico malicioso.



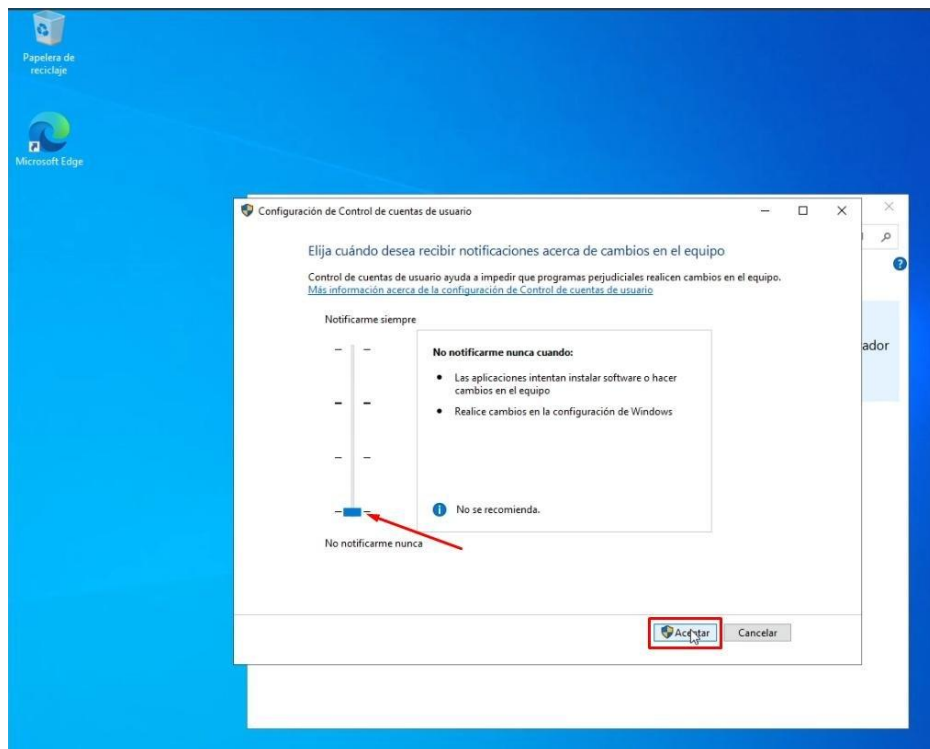
Paso 6: En el apartado de Windows Update, observo que hay múltiples actualizaciones acumulativas y de seguridad pendientes de instalación, las cuales dejo sin aplicar para mantener brechas críticas explotables por el escáner.



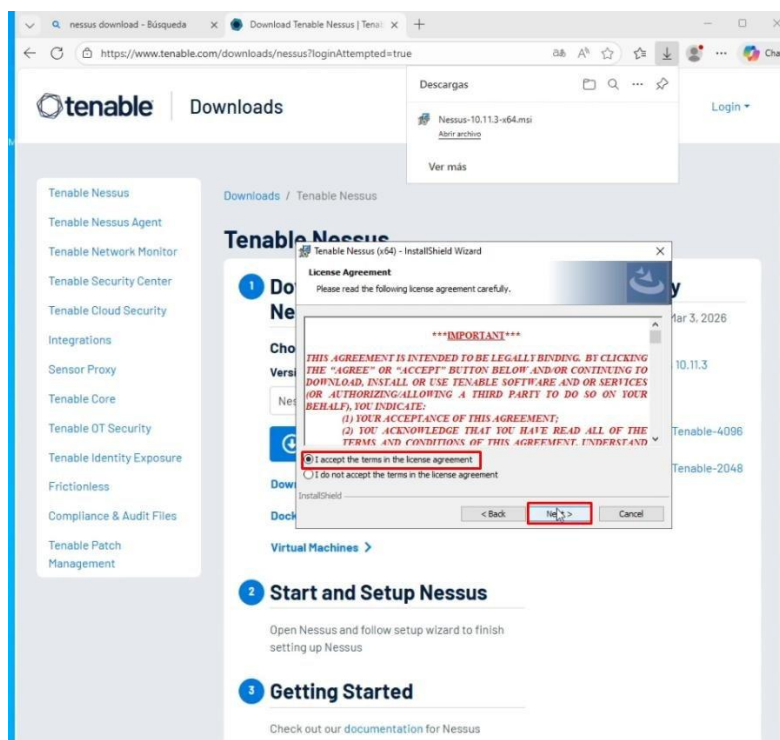
Paso 7: Me dirijo a la sección de Cuentas de usuario y hago clic en "Cambiar configuración de Control de cuentas de usuario" para reducir las notificaciones de seguridad que bloquean cambios no autorizados en el equipo.



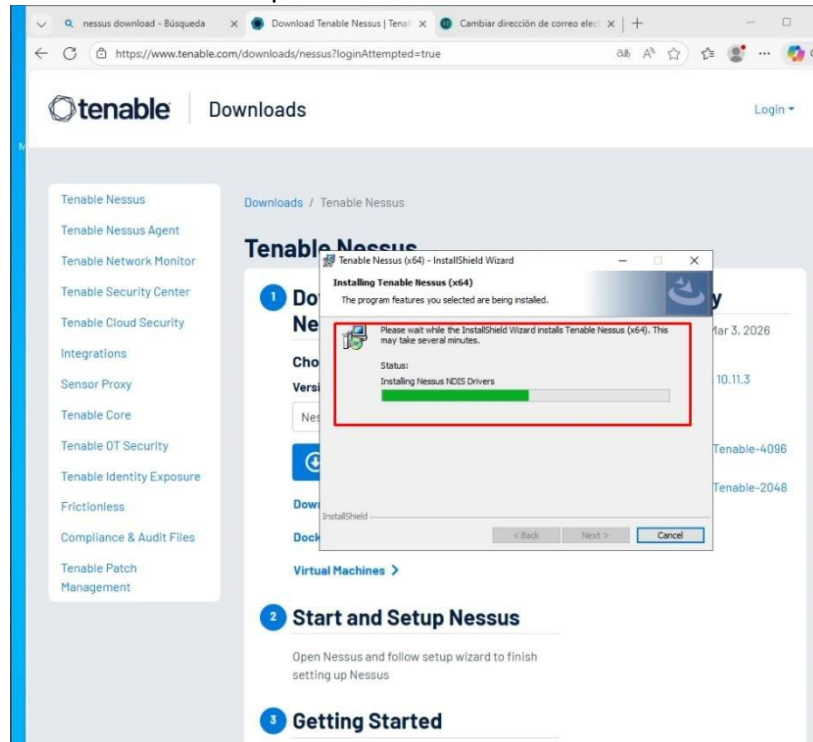
Paso 8: Deslizo la barra del **UAC** hasta el nivel inferior "No notificarme nunca", desactivando una capa esencial de defensa, y presiono "Aceptar" para confirmar esta configuración de alto riesgo en el controlador de dominio.



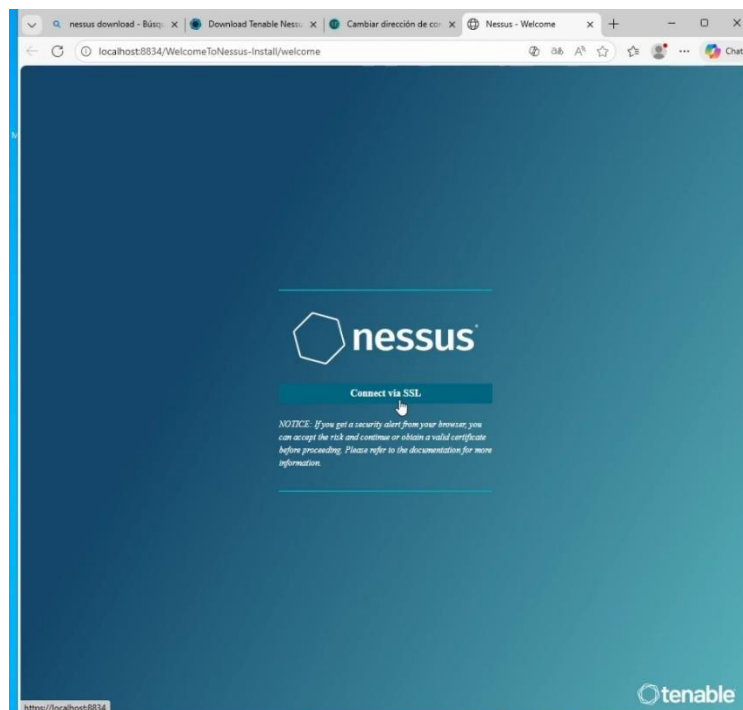
Paso 9: Dentro del asistente de instalación, marco la casilla "I accept the terms in the license agreement" para aceptar el acuerdo de licencia y presiono "Next" para avanzar con la configuración del software.



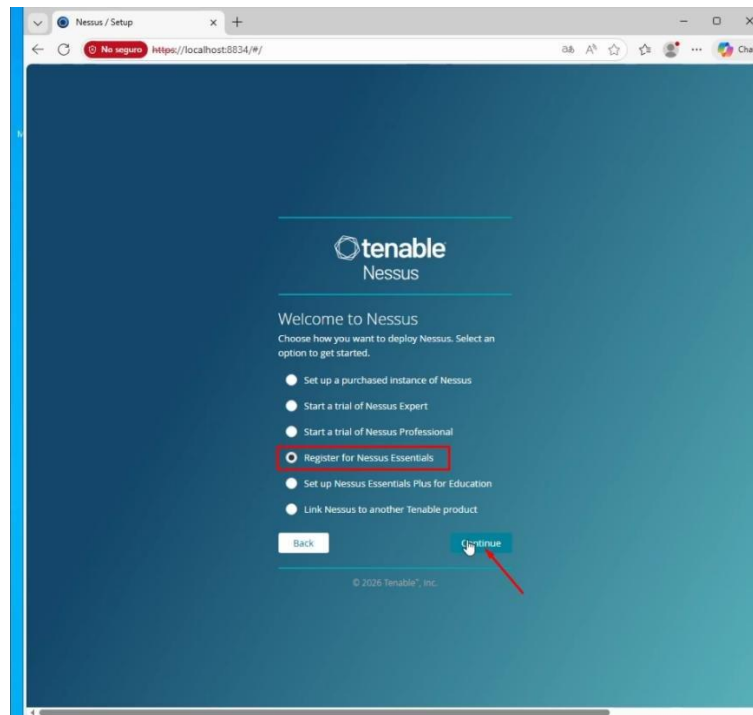
Paso 10: Monitoreo el progreso de la instalación mientras el sistema despliega los controladores necesarios, específicamente los **Nessus NDIS Drivers**, asegurando que la interfaz de red esté lista para el escaneo.



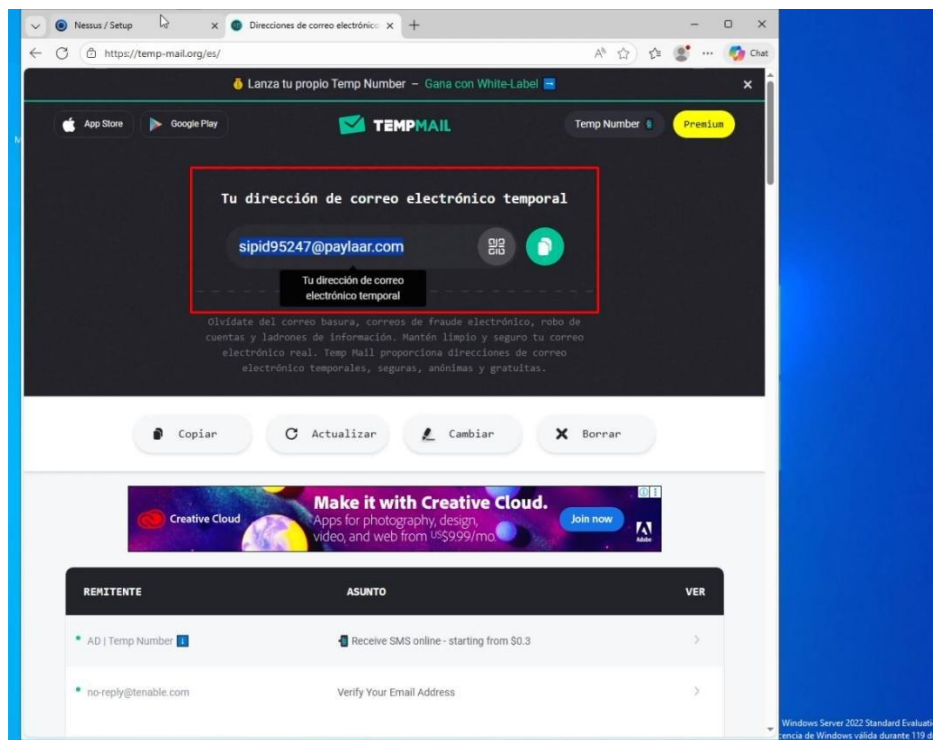
Paso 11: Finalizada la instalación, abro el navegador y accedo a la dirección <https://localhost:8834>, donde hago clic en el botón "Connect via SSL" para establecer una conexión segura con la consola local.



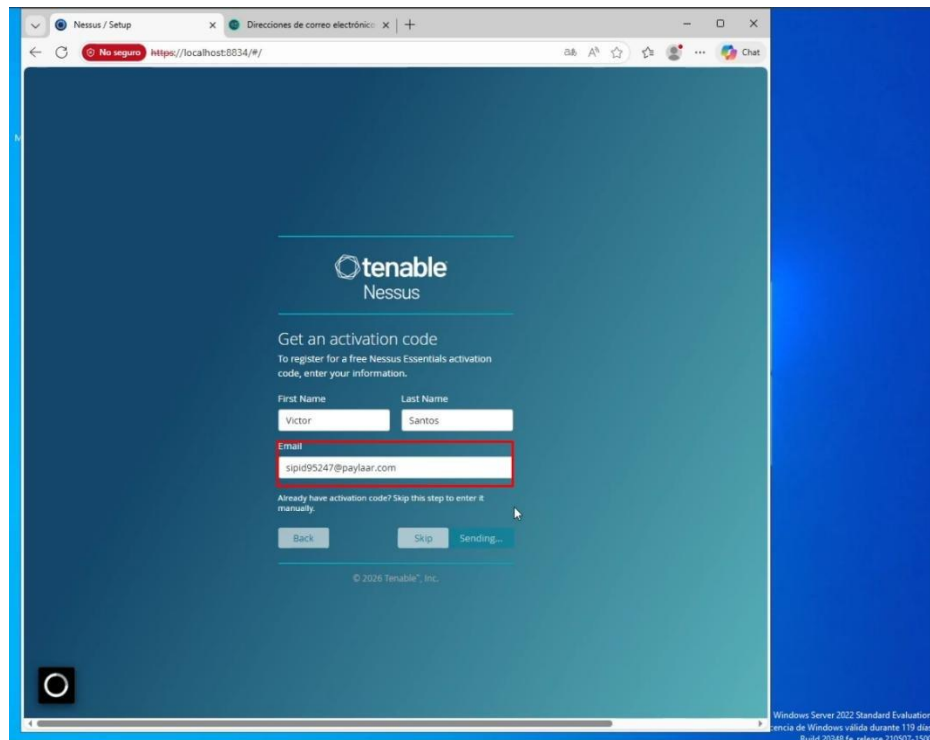
Paso 12: En la pantalla de bienvenida, selecciono la opción "Register for Nessus Essentials" entre las alternativas de despliegue y presiono "Continue" para proceder con el registro de la versión gratuita.



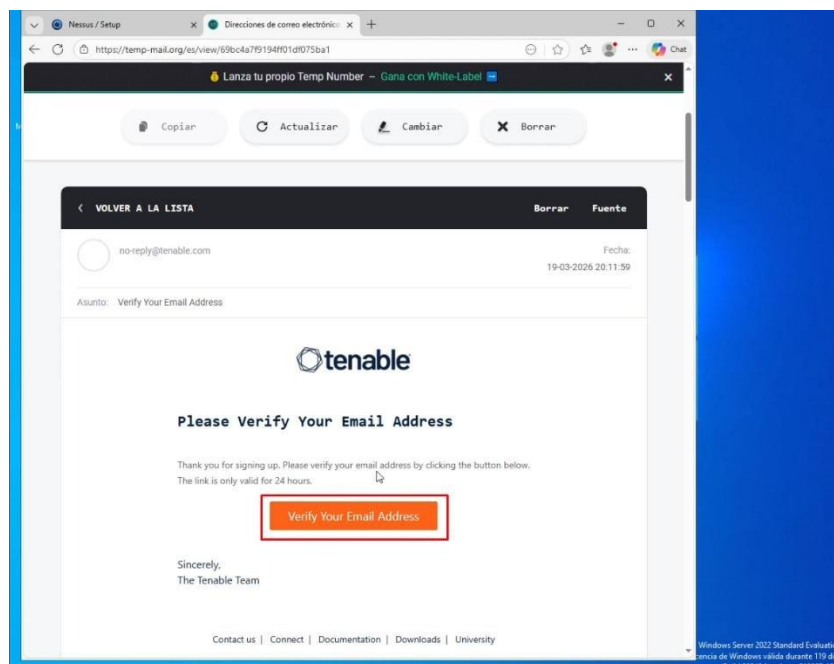
Paso 13: Utilizo el servicio de **Temp Mail** para generar una dirección de correo electrónico temporal sipid95247@paylaar.com, la cual copiaré para recibir el código de activación sin comprometer mi cuenta personal.



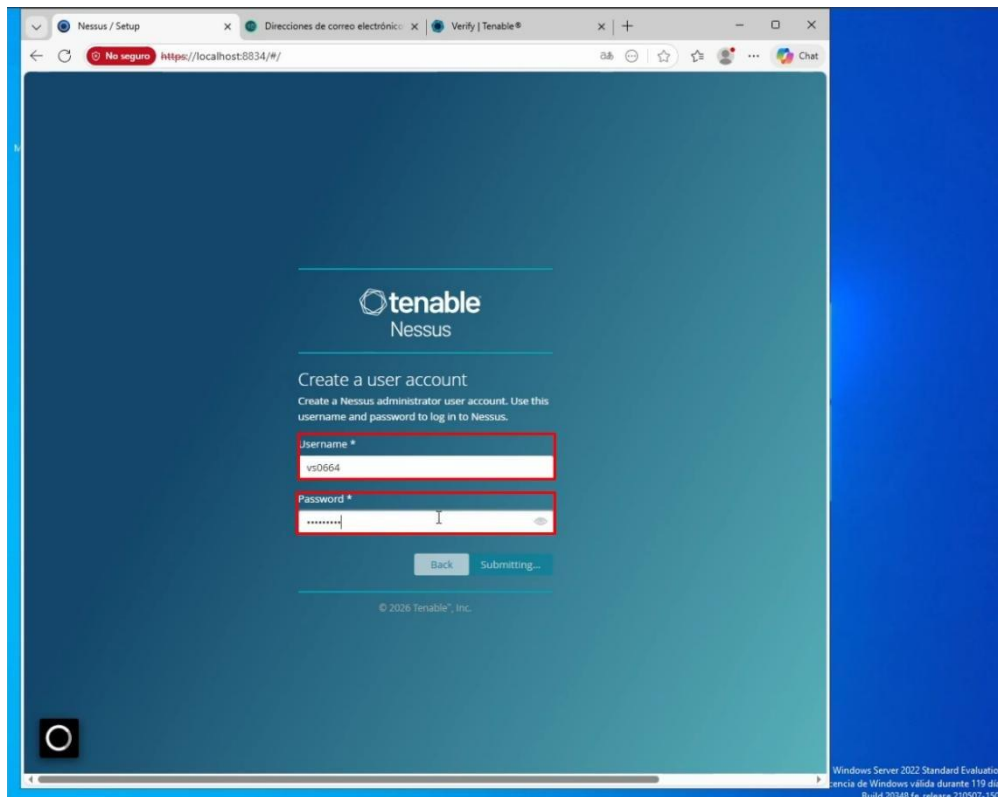
Paso 14: Introduzco mi nombre y el correo temporal generado en el formulario de registro de Tenable para solicitar el **Activation Code** necesario para habilitar todas las funciones de escaneo del programa.



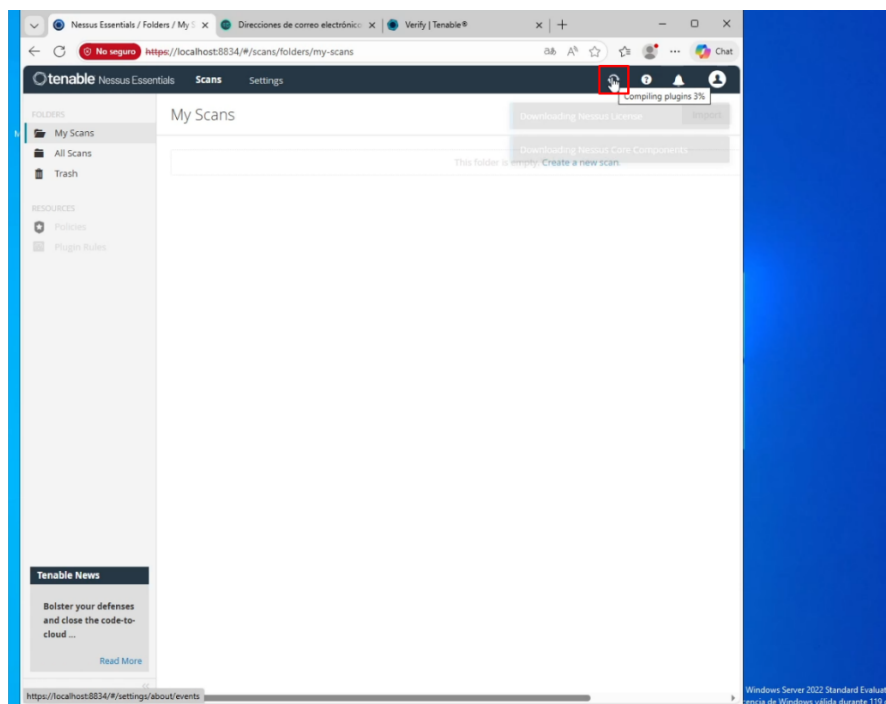
Paso 15: Accedo a la bandeja de entrada del correo temporal y abro el mensaje de "Tenable Team" para hacer clic en el botón "Verify Your Email Address", validando así mi solicitud de licencia.



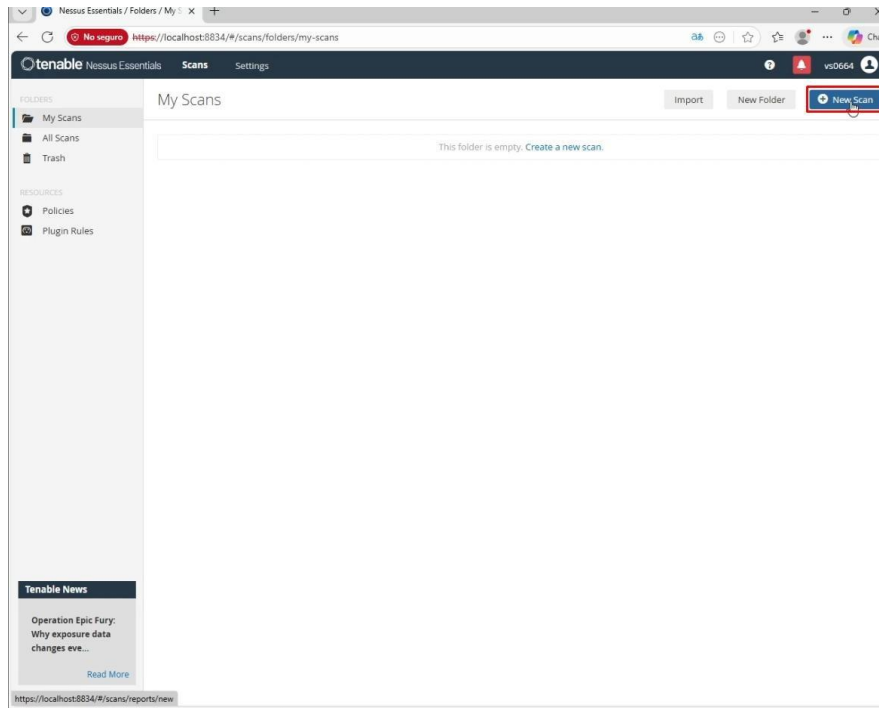
Paso 16: Tras la verificación, procedo a crear mi cuenta de administrador local en Nessus definiendo el nombre de usuario **vs0664** y una contraseña, finalizando el proceso con el botón "Submit".



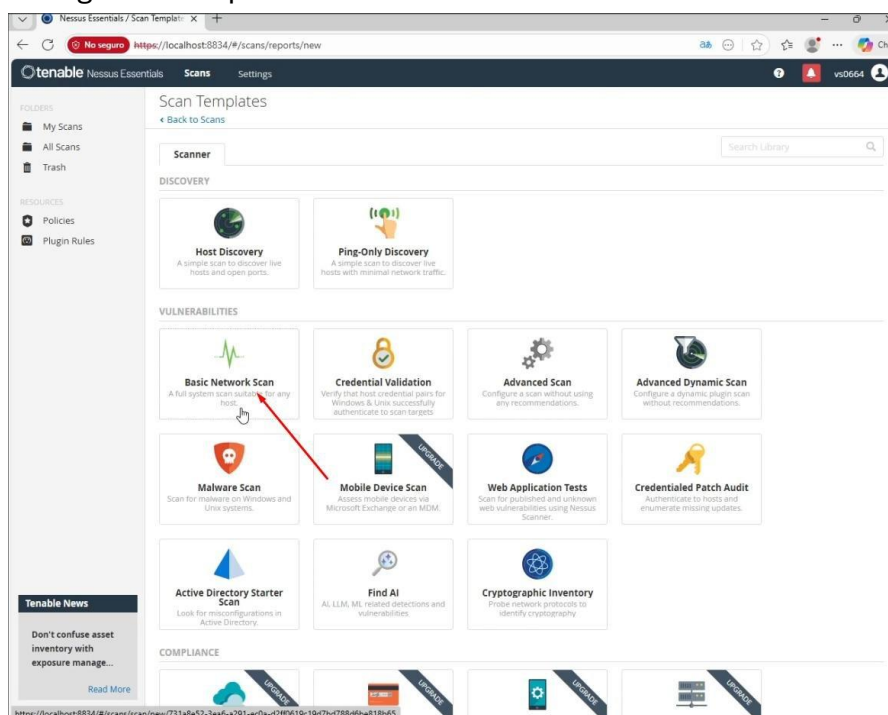
Paso 17: Finalmente, entro al panel principal de **Nessus Essentials** y espero a que el sistema complete el proceso de "Compiling plugins", el cual es fundamental para que la herramienta reconozca las últimas vulnerabilidades.



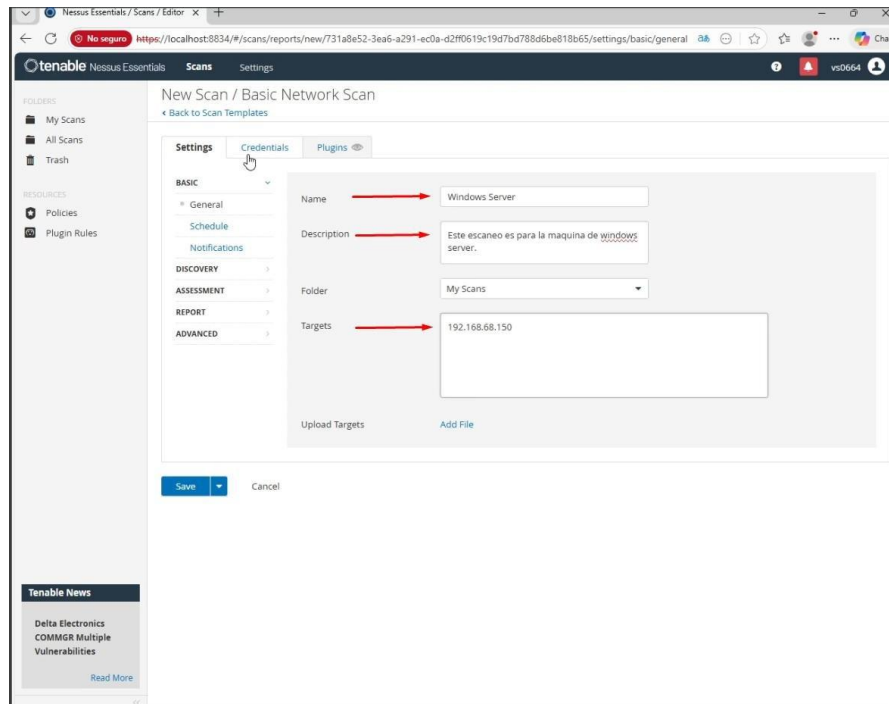
Paso 18: En el panel principal de Nessus, hago clic en el botón **"New Scan"** ubicado en la esquina superior derecha para iniciar la configuración de una nueva tarea de auditoría sobre mi infraestructura.



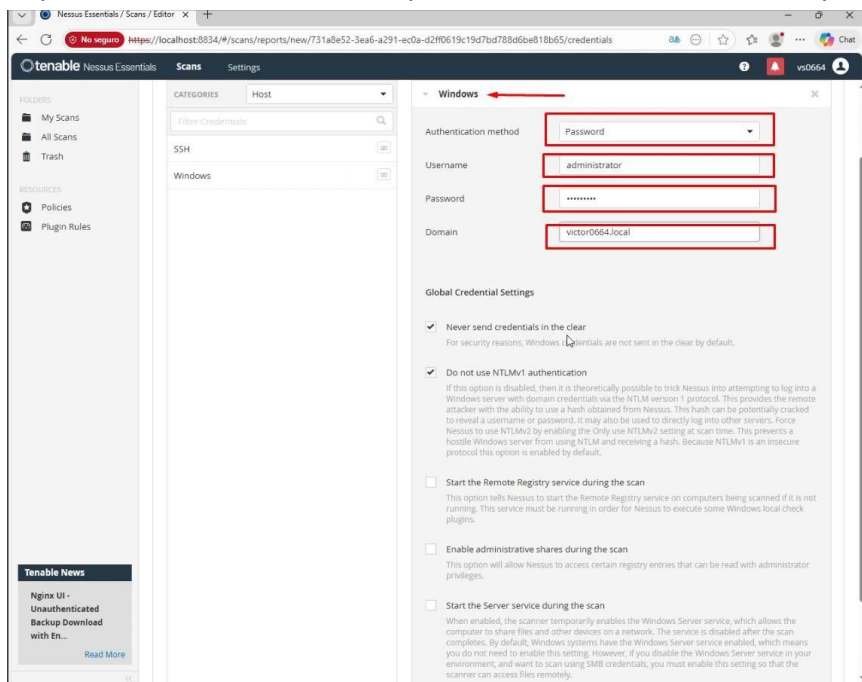
Paso 19: Selecciono la plantilla **"Basic Network Scan"** de la lista de opciones disponibles, la cual es ideal para realizar un análisis completo del sistema y detectar fallas de configuración o parches faltantes.



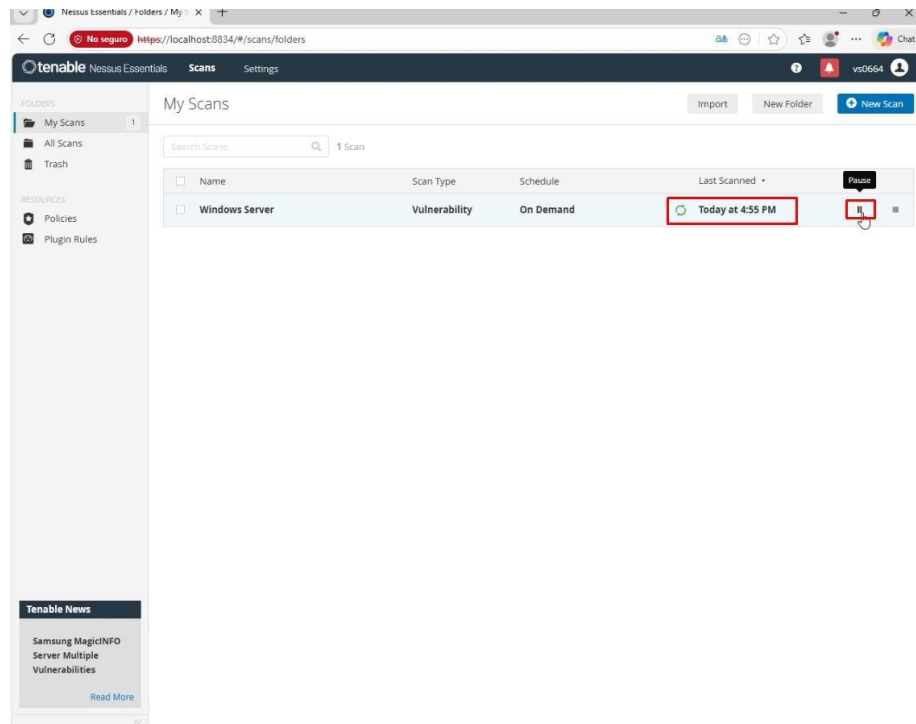
Paso 20: Configuro los detalles generales del escaneo asignándole el nombre "Windows Server" e ingreso la dirección IP 192.168.68.150 en el campo **Targets** para apuntar directamente hacia mi controlador de dominio.



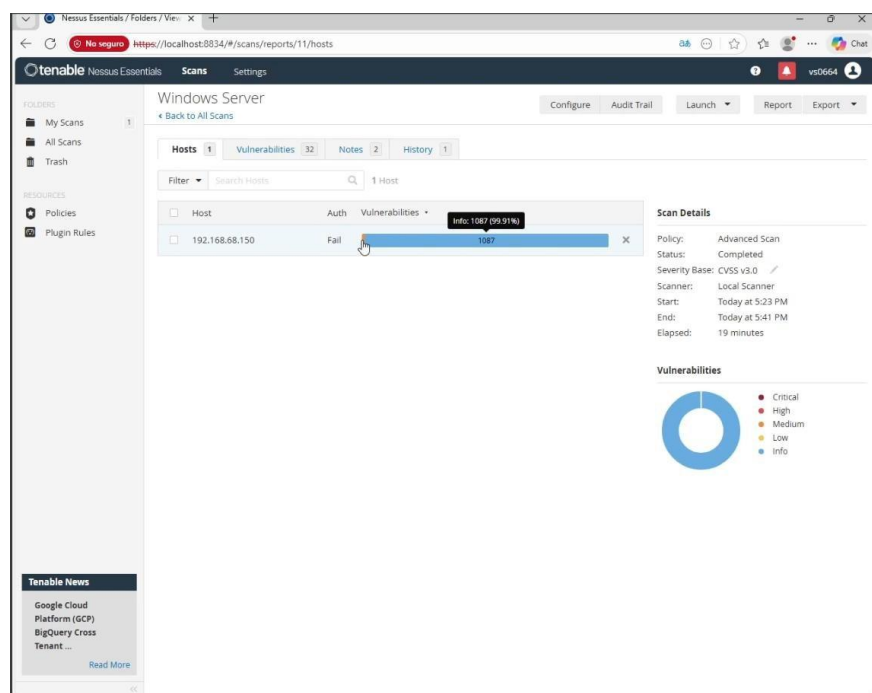
Paso 21: Me dirijo a la pestaña "**Credentials**", selecciono la categoría "Windows" y proporciono las credenciales del administrador del dominio victor0664.local para que Nessus pueda realizar un escaneo profundo dentro del sistema operativo.



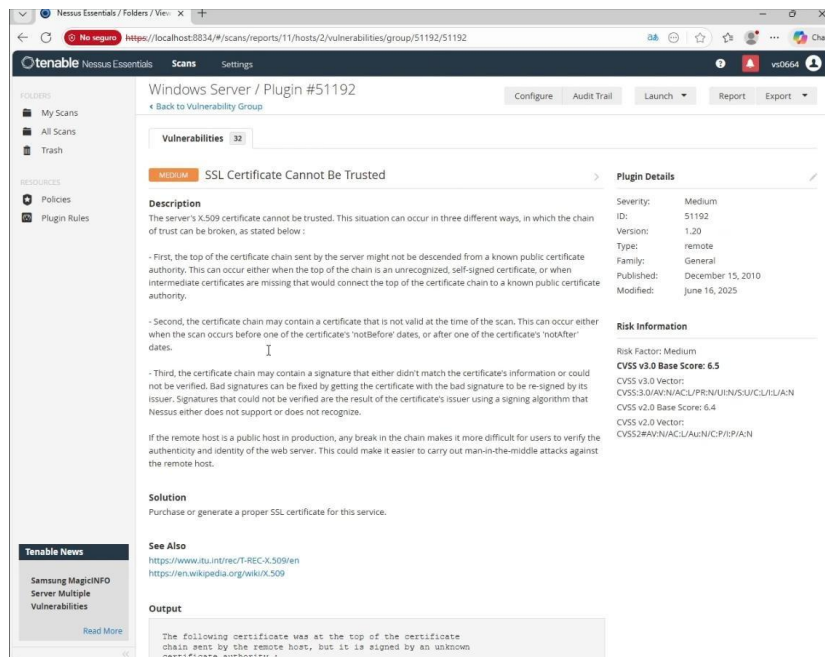
Paso 22: Inicio la ejecución del escaneo y monitoreo el progreso desde la lista de "My Scans", donde verifico que el estado cambie a un icono de carga verde indicando que la herramienta está analizando el servidor en tiempo real.



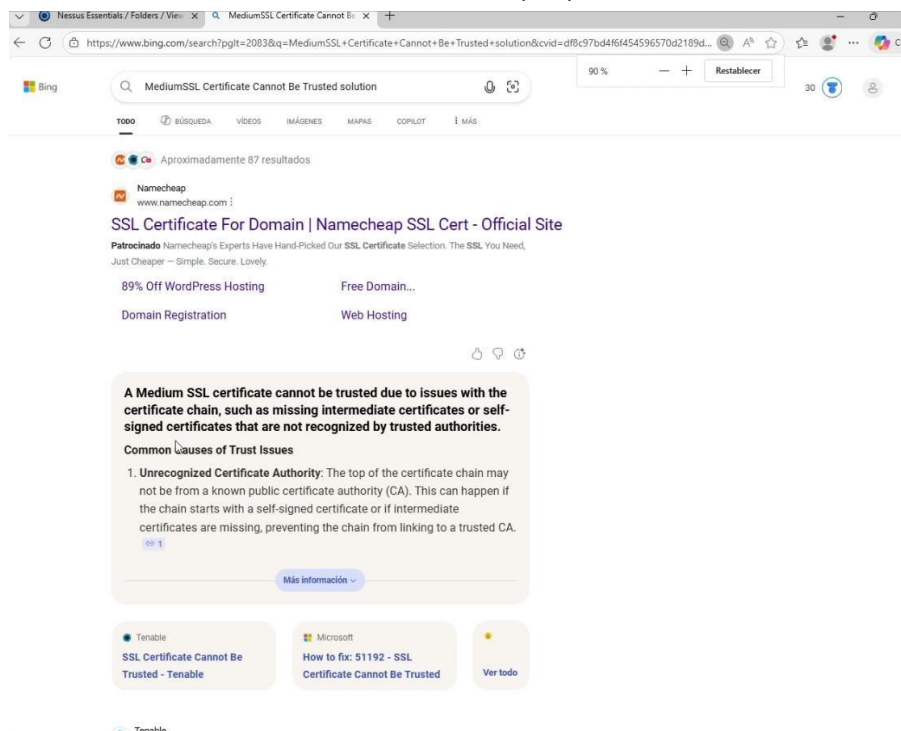
Paso 23: Una vez finalizado el proceso, accedo a los resultados donde se visualiza un resumen con **1087 hallazgos**, identificando vulnerabilidades de severidad crítica, alta y media que requieren atención inmediata para proteger el servidor. (Mi maquina se clicho porque con todas esas malas configuraciones y versiones de Windows debería de tener mas vulns).



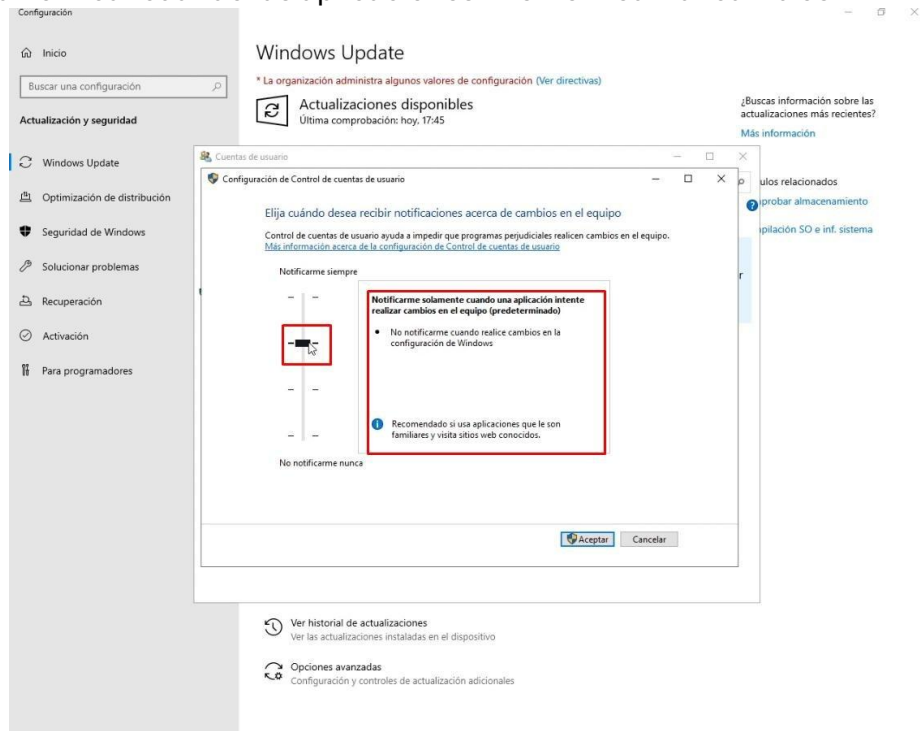
Paso 24: Analizo específicamente la vulnerabilidad de nivel **Medium** denominada "SSL Certificate Cannot Be Trusted", la cual indica que el certificado X.509 del servidor no es válido o proviene de una entidad no reconocida.



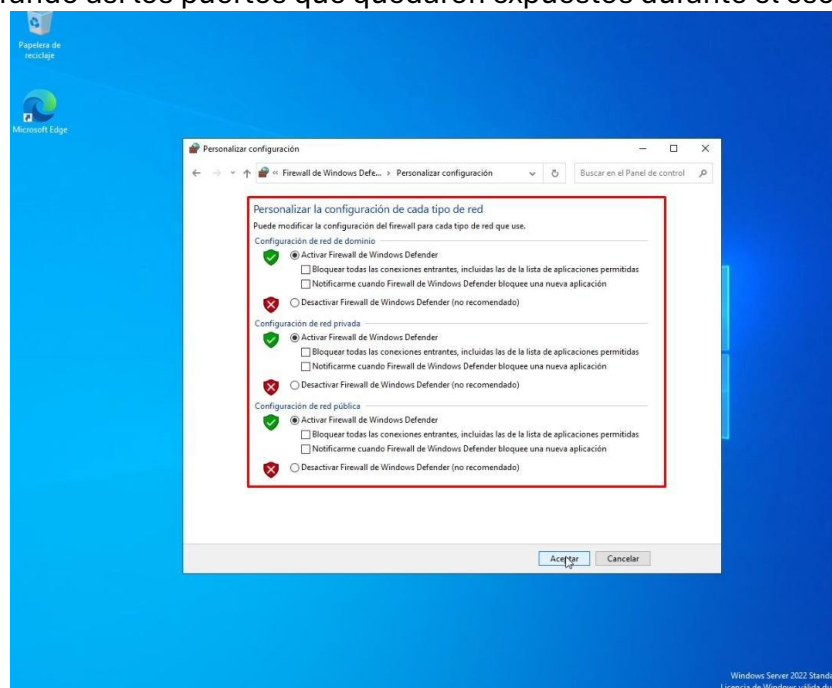
Paso 25: Utilizo el buscador para investigar soluciones a la vulnerabilidad detectada, confirmando que la causa principal es el uso de certificados autofirmados o la ausencia de una autoridad de certificación (CA) confiable en la cadena.



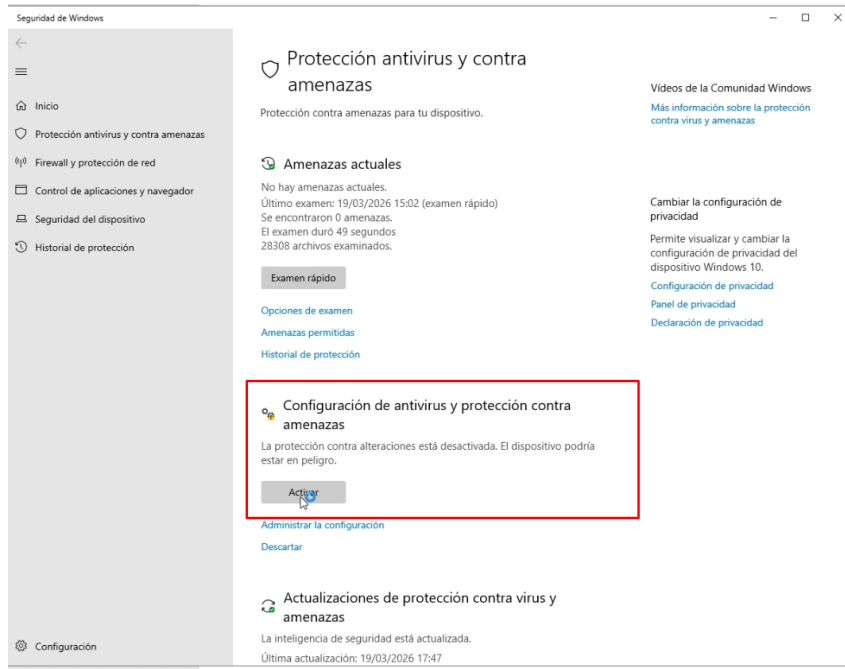
Paso 26: Comienzo la fase de remediación regresando a la configuración del UAC para subir el nivel de protección a "Predeterminado", asegurando que el sistema vuelva a notificar cuando las aplicaciones intenten realizar cambios.



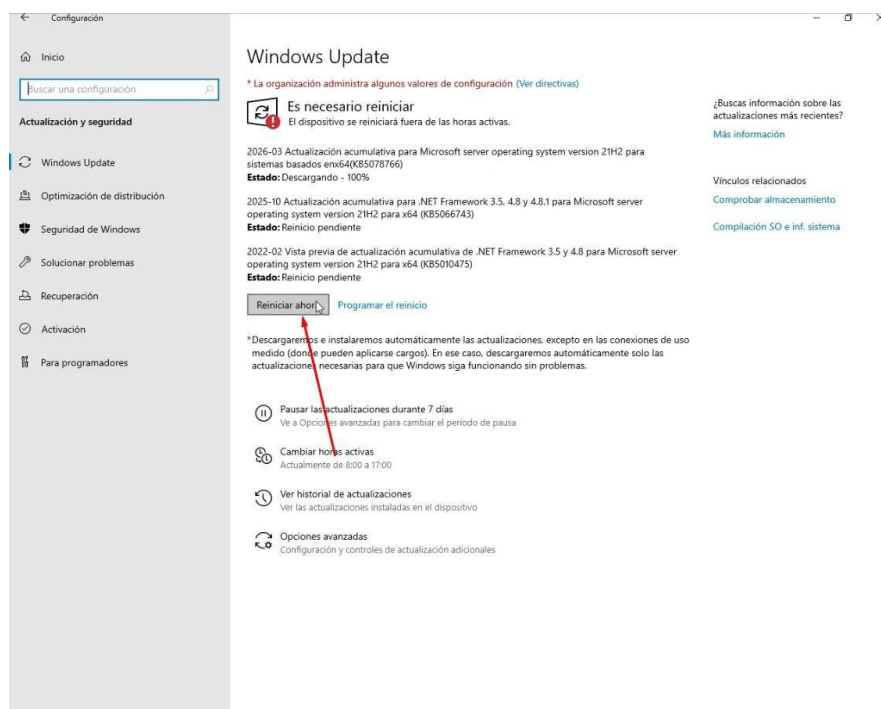
Paso 27: Accedo nuevamente a la configuración del Firewall de Windows Defender y marco la opción "Activar Firewall de Windows Defender" para todos los perfiles de red, cerrando así los puertos que quedaron expuestos durante el escaneo.



Paso 28: Me dirijo a la sección de Protección antivirus y contra amenazas de Windows para hacer clic en el botón **"Activar"** dentro de la configuración de protección contra alteraciones, restableciendo así las defensas activas del sistema operativo.



Paso 29: Accedo al apartado de Windows Update y procedo a hacer clic en **"Reiniciar ahora"** para aplicar todas las actualizaciones acumulativas y parches de seguridad de .NET Framework que se encontraban pendientes de instalación.



Paso 30: Ejecuto un nuevo escaneo de verificación en Nessus y compruebo que la lista de vulnerabilidades críticas y medias ha desaparecido, dejando únicamente hallazgos de tipo "INFO", lo que confirma que el servidor ya es seguro.

